

1 You really need this?

FIELD REVIEW



Go through every data category with the project team and drop what nobody can justify.

Every field arrives with the same defence: "it might be useful someday."

SDM D1.7 · NIST SI-12(1), PT-3

MIN-FIELDS-1 · v0.8

3 35-55 is enough

GENERALISE VALUES



Replace exact birth dates with age bands. You still know who is in the group, but not who was born when.

Age bands keep the crowd and lose the candles. (Marketing will ask where the candles went.)

SDM D1.7 · NIST SI-19

MIN-FIELDS-2 · v0.8

3 Answer, don't keep

DON'T STORE IT



Check the answer once, for example "over 18", and store only the result, not the birth date it came from.

It cannot leak what it never kept.

SDM D3.4, D1.7 · NIST SI-19(1), SA-8

MIN-FIELDS-3 · v0.8

1 Only while it's needed

COLLECTION RULE PER PURPOSE



Write down what may be collected for each purpose and for how long.

The rule is clear. Finding out who enforces it is the sequel.

SDM D1.7 · NIST PT-3

MIN-WINDOW-1 · v0.8

2 Only when it matters

EVENT-BASED COLLECTION



Collect on a trigger instead of continuously, and pause automatically outside the purpose window.

Turns out nobody needed a reading every ten seconds. Not even the sensor.

SDM D1.7

MIN-WINDOW-2 · v0.8

1 Retention policy (on paper)

RETENTION SCHEDULE



Write down how long each kind of data is kept.

Step 1: Write the policy. Step 2: Admire the policy. Step 3: There is no step 3.

SDM D1.7 · NIST SI-12

MIN-RETAIN-1 · v0.8

3 The nightly purge

AUTOMATIC DELETION



A scheduled job deletes everything that is past its retention date.

It has also, once, deleted what it should not have. We do not talk about Q3.

SDM D1.7 · NIST SI-12(3)

MIN-RETAIN-2 · v0.8

3 Totals, not people

KEEP AGGREGATES ONLY



After a set time, replace individual records with totals and statistics.

Perfect for the dashboard. Terrible for the one question nobody asked yet.

SDM D1.7 · NIST SI-19(5)

MIN-RETAIN-3 · v0.8

1 Names optional

REPORTS WITHOUT PERSONAL COLUMNS



Make reports and default views show no names or IDs unless someone needs them.

Funny how few people miss the name column.

SDM D1.7 · NIST AC-3

MIN-VIEW-1 · v0.8



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE

2 Black bars

1

FIELD MASKING

-2|0 -1|0

Masked fields stay hidden and are revealed only for a recorded reason. Since the masking feature of the platform works for any field, you can **REUSE** it in every project now for 1 extra cost per project.

Every black bar starts a conversation about who may lift it.

SDM D1.7 · NIST SI-19(4), AC-3

MIN-VIEW-2 · v0.8

3 Nobody has to look

AUTOMATE SO NOBODY HAS TO LOOK

-3|0 -1|0

Let the system handle the case end to end, so people only see the exceptions.

The exceptions are, of course, where the interesting data lives.

SDM D1.7

MIN-VIEW-3 · v0.8

1 Not in the test system

NO LIVE DATA IN TESTS

-1|0 -1|0

Never copy production personal data into test or training environments.

Famous last words: "it is only a copy."

SDM D1.7 · NIST PM-25, SI-12(2)

MIN-TEST-1 · v0.8

3 Realistic nobodies

1

SYNTHETIC OR MASKED TEST DATA

-2|0 -1|0

Generate test data that behaves like the real thing but belongs to no one. Since the generator works on any schema, you can **REUSE** it in every project now for 1 extra cost per project.

Mr. Test-Testmann has been in every database since 2009.

SDM D1.7 · NIST PM-25, SI-19(4)

MIN-TEST-2 · v0.8

1 Off until you say so

OPTIONAL FEATURES OFF BY DEFAULT

-2|0 -1|0

Optional features start switched off and need an active opt-in.

Marketing calls it "a missed opportunity". Everyone else calls it "the default".

SDM D1.7, B1.17 · NIST SA-8

MIN-DEFAULT-1 · v0.8

2 Why do you want it?

PURPOSE REGISTER AND APPROVAL

-1|0 -1|0 +1|0

Keep one register of what each dataset is for and require approval before it is used for anything new. You go **GLOBAL** with the register service once, and from now on every project is checked against it.

"For analytics" has now been entered as the purpose forty times.

SDM D1.4 · NIST PT-2, PT-3

LNK-PURPOSE-1 · v0.8

3 Separate drawers

SEPARATE STORES PER PURPOSE

-2|0 -1|0

Keep data for different purposes in separate stores with separate access paths.

It was one big table because that was easier. It was always going to be easier.

SDM D1.4, Baustein 50 · NIST AC-4

LNK-PURPOSE-2 · v0.8

4 Different house

SEPARATE ORGANISATION OR TENANT

-3|0 -1|0 +1|0

Let a separate team or legal entity hold the data of the other purpose, on its own platform. You go **GLOBAL** with that platform once, and from now on every project lives on it.

Legal calls it "organisational separation". Everyone else calls it "the other building".

SDM D1.4 · NIST SC-7

LNK-PURPOSE-3 · v0.8

3 Names stay in the vault

1

PSEUDONYMISE, KEY HELD SEPARATELY

0|-1 0|-1 0|-1 0|+1

You introduce a pseudonymisation service: names go in, tokens come out, the key stays in the vault. Since the vault knows nothing about your data model, you can **REUSE** it in every project now for 1 extra cost per project.

The vault password is, hopefully, not on a sticky note.

SDM D1.4 · NIST SI-19(4), SC-12

LNK-ID-1 · v0.8



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE

3

A new name for every occasion

1

DIFFERENT PSEUDONYM PER PURPOSE

0|-2

0|+1

Give the same person a different pseudonym for each purpose, so records cannot be matched across them. Since the pseudonymisation service already issues the tokens, you can **REUSE** it in every project now for 1 extra cost per project.

Great for privacy. Less great for the colleague who just wants to join two tables.

SDM D1.4 · NIST SI-19(4)

LNK-ID-2 · v0.8

4

Safety in numbers

2

ANONYMISE WITH THRESHOLDS

0|-3

0|-1

Publish only groups above a minimum size and add noise to statistics, so nobody can be picked out. Since the anonymisation tool works on any table, you can **REUSE** it in every project now for 2 extra cost per project.

A group of two is not a group. It is a pair, and it has names.

SDM D1.4 · NIST SI-19(5), SI-19(6)

LNK-ID-3 · v0.8

2

Not without sign-off

ONWARD SHARING NEEDS APPROVAL

-1|0

+1|0

Require sign-off before data goes to another system or party. You go **GLOBAL** with the approval tool once, and from now on every project needs it.

The sign-off took three weeks. The integration was cancelled in week two.

SDM D1.4 · NIST AC-21

LNK-SHARE-1 · v0.8

2

Delete the export button

CLOSE UNUSED INTERFACES

-2|0

-1|0

Remove export functions and interfaces nobody needs.

Somebody needed it in 2019. Nobody remembers who.

SDM D1.4 · NIST AC-4, SC-7

LNK-SHARE-2 · v0.8

3

No bulk buffet

1

LIMIT BULK QUERIES AND PROFILING

-2|0

-1|0

Cap bulk exports and queries that combine many records. Since the gateway that enforces the limits sits in front of any system, you can **REUSE** it in every project now for 1 extra cost per project.

"Just download everything and filter it locally" is a plan with a future.

NIST AC-23

LNK-MINING-1 · v0.8

3

Who still needs this?

ROLES WITH YEARLY REVIEW

-1|0

-1|0

-1|0

+1|0

Give access by job, give every role an owner and recertify it every year. You go **GLOBAL** with the review tool once, and from now on it runs for every project.

The annual review finds the intern from 2017 still has admin rights.

SDM D1.3, Baustein 51 · NIST AC-2, AC-6

CON-ACCESS-1 · v0.8

3

Only your own patch

2

ACCESS BY UNIT OR CASE

-2|0

-1|0

-1|0

Show staff only the records of their own unit, region or case. Since the access platform can scope any system the same way, you can **REUSE** it in every project now for 2 extra cost per project.

Head office learns what "need to know" means when it asks for a country-wide report.

SDM D1.3 · NIST AC-3, AC-16

CON-ACCESS-2 · v0.8

3

Break glass in emergencies

APPROVAL FOR SENSITIVE RECORDS

-3|0

-1|0

+1|0

Require a second person's approval and a stated reason before anyone opens a sensitive record.

The emergency was, it turns out, a Friday afternoon.

SDM D1.3 · NIST AC-5, AC-2(2)

CON-ACCESS-3 · v0.8

2

Signed, sealed, ignored

CONTRACT AND STATED REASON

-1|0

Bind supplier staff by contract to confidentiality and make them name a reason for every access. You go **GLOBAL** with the framework contract once, and from now on every supplier signs it.

A contract cannot stop anyone. It can only make them regret it.

SDM D1.3 · NIST PS-6, SA-9

CON-SUPPLIER-1 · v0.8



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE

3 Ticket #4711

1

JUST-IN-TIME LOGGED ACCESS

-2|0 -1|0 +1|0

You introduce an access tool that gives the supplier's support a key for one ticket and a few hours. When the ticket closes, the key expires. Since the tool works for any supplier, you can **REUSE** it in every project now for 1 extra cost per project.

Whoever waits for the approval will call this "friction".

SDM D1.3 · NIST AC-2(2), AU-2

CON-SUPPLIER-2 · v0.8

4 Supplier, keep out

NO SUPPLIER ACCESS

-3|0 +1|0

Run it in your own tenancy or on your own premises so the supplier cannot read the data.

The supplier's support will now ask you to share your screen. Welcome back.

SDM D1.3 · NIST SC-12, SC-28

CON-SUPPLIER-3 · v0.8

3 Locked at rest

AT-REST ENCRYPTION, MANAGED KEYS

0|-1

Encrypt disks and databases and manage the keys centrally. You go **GLOBAL** with the key service once, and from now on every project is covered.

Excellent protection against someone walking out with the disk.

SDM D1.3 · NIST SC-28, SC-12

CON-KEYS-1 · v0.8

3 Locked per field

1

FIELD-LEVEL ENCRYPTION

0|-2 0|+1

Encrypt sensitive attributes individually so even administrators cannot read them. Since the encryption library works on any field, you can **REUSE** it in every project now for 1 extra cost per project.

Searching on that column is now a fond memory.

SDM D1.3 · NIST SC-28, SC-13

CON-KEYS-2 · v0.8

4 Our keys, not yours

CUSTOMER-HELD KEYS

0|-3 0|+1

Hold the keys yourself so the provider cannot decrypt anything. You go **GLOBAL** with the key custody service once, and from now on it applies to every project.

Lose the key and you have achieved perfect confidentiality, for everyone, forever.

SDM D1.3 · NIST SC-12

CON-KEYS-3 · v0.8

3 Plus one more factor

MULTI-FACTOR AUTHENTICATION

-1|0 -1|0 +1|0

Require a second factor from everyone who can reach personal data. You go **GLOBAL** with the sign-in service once, and from now on every project signs in the same way.

The phone with the app is, of course, in the other bag.

SDM D1.3 · NIST IA-2(1), IA-2(2)

CON-AUTH-1 · v0.8

3 A key you can't phish

PHISHING-RESISTANT AUTHENTICATION

-2|0 -1|0 +1|0

Use hardware security keys for access to sensitive data. You go **GLOBAL** with them once, and from now on every project accepts only them.

The phishing emails still arrive. They now get a very polite refusal.

SDM D1.3, D3.4 · NIST IA-2, IA-5

CON-AUTH-2 · v0.8

2 Does it treat people alike?

BIAS AND ERROR TEST BEFORE LAUNCH

-1|0 -1|0

Before launch, test automated results for errors and for disadvantage to groups of people.

The model is 94% accurate. Nobody asked for whom.

SDM D1.2, B1.16 · NIST SA-11

INT-DECISION-1 · v0.8

3 The scoreboard

2

REGULAR OUTCOME MONITORING

-2|0 -1|0

Check the results by group every quarter. Since the monitoring dashboard can read any model's outputs the same way, you can **REUSE** it in every project now for 2 extra cost per project.

Quarter-end is when everyone discovers the model drifted in February.

SDM D1.2, B1.16

INT-DECISION-2 · v0.8



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE

3 A stranger checks the maths

2

INDEPENDENT AUDIT

-3|0

-1|0

Let an independent party validate the model and its data. Since the audit method is the same for any model, you can **REUSE** it in every project now for 2 extra cost per project.

The auditor's first question is "where is the documentation?". The second is worse.

SDM D1.2, D4

INT-DECISION-3 · v0.8

2 Born in the year 3000?

PLAUSIBILITY CHECKS AT INPUT

-1|0

Reject impossible values at input, before they feed a decision.

The system accepted "born in 1900" as a feature, not a bug.

SDM D1.2, B1.4 · NIST SI-10, SI-18

INT-INPUT-1 · v0.8

3 Fix it once

2

CORRECTION LOOP WITH PROPAGATION

0|-2

0|-1

When a value is corrected at the source, make the fix reach every copy. Since the sync service works for any connected system, you can **REUSE** it in every project now for 2 extra cost per project.

There are four copies of that record. You have found three.

SDM D1.2 · NIST SI-18(4), SI-18(5)

INT-INPUT-2 · v0.8

2 Four eyes

FOUR-EYES ON SENSITIVE CHANGES

-1|0

Require a second person to approve edits to records that affect people.

Both people assumed the other one had checked.

SDM D1.2 · NIST AC-5, CM-5

INT-CHANGE-1 · v0.8

3 Spot the edit

1

TAMPER-EVIDENT RECORDS

0|-2

0|-1

Use checksums, signatures or append-only storage so changes cannot pass unnoticed. Since the integrity service seals records the same way everywhere, you can **REUSE** it in every project now for 1 extra cost per project.

The record was changed on a Sunday at 3 a.m. At least you know now.

SDM D1.2 · NIST SI-7

INT-CHANGE-2 · v0.8

2 Paper still works

DOCUMENTED MANUAL FALLBACK

0|-1

Document a manual process that takes over during an outage, so people are not disadvantaged.

The binder with the procedure is stored in the system that is down.

SDM D1.1 · NIST CP-2

AVL-FALLBACK-1 · v0.8

2 Fire drill

1

REHEARSED FALLBACK

0|-2

Rehearse the fallback every year. Since the drill plan fits any process, you can **REUSE** it in every project now for 1 extra cost per project.

Half the team learned the fallback exists during the drill.

SDM D1.1 · NIST CP-4

AVL-FALLBACK-2 · v0.8

4 A second one, just in case

REDUNDANT CRITICAL FUNCTIONS

-2|0

+1|0

+1|0

Keep a second site that takes over automatically when the first one fails. You go **GLOBAL** with it once, and from now on every project runs on that platform.

Now there are two places to protect, to patch and to forget about.

SDM D1.1 · NIST CP-6, CP-7

AVL-REDUNDANCY-1 · v0.8

2 Who covers on Friday?

DEPUTIES FOR KEY ROLES

-2|0

Name a substitute for every key role. You go **GLOBAL** with the roster once, and from now on every project has one.

The substitute is on holiday too. It was in the plan.

SDM D1.1

AVL-DEPUTY-1 · v0.8



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE

1 What goes into the score?

DOCUMENT SCORING FACTORS

0|-1

Write down which factors feed a score or an automated decision.

Factor number seven is "other".

SDM D1.5

TRA-SCORE-1 · v0.8

2 In plain words

EXPLAIN FACTORS IN PLAIN LANGUAGE

0|-2

0|-1

Explain in everyday language to the people affected which factors count.

Legal approved the wording. Nobody has read it since.

SDM D1.5, B1.1

TRA-SCORE-2 · v0.8

3 Show your working

REASONS PER DECISION

0|-3

0|-1

Give every decision the reasons behind it, so people can contest it.

"The model said so" is not a reason, but it does fit on one line.

SDM D1.5

TRA-SCORE-3 · v0.8

2 Right there, right then

JUST-IN-TIME NOTICE

0|-1

Show a short notice at the exact moment data is collected. Since the notice component works in any screen or form, you can **REUSE** it in every project now for 1 extra cost per project.

Read by roughly three people, one of them from legal.

SDM D1.5 · NIST PT-5(1)

TRA-NOTICE-1 · v0.8

4 Who looked at me?

"WHO ACCESSED MY DATA" VIEW

0|-2

0|-1

0|+1

Let people see who accessed their records. You go **GLOBAL** with the access view service once, and from now on every project shows it.

Everyone is shocked how often their own manager looks.

SDM D1.5

TRA-NOTICE-2 · v0.8

2 Who opened this file?

LOG ACCESS TO SENSITIVE DATA

-1|0

-1|0

+1|0

You roll out a logging platform that records who opened which record, and when. Since the platform logs any system the same way, you can **REUSE** it in every project now for 1 extra cost per project.

Most days nobody reads it. Then someone looks up their neighbour, and the platform remembers.

SDM D1.5, Baustein 43 · NIST AU-2

TRA-LOG-1 · v0.8

2 Somebody reads the log

REVIEW LOGS AND ALERT

-2|0

-1|0

-1|0

Analyse the logs regularly and raise alerts for unusual access. Since the alerting service reads any log format, you can **REUSE** it in every project now for 1 extra cost per project.

Alert fatigue arrives in week two.

SDM D1.5 · NIST AU-6, SI-4

TRA-LOG-2 · v0.8

4 Even the admins can't edit this

TAMPER-PROTECTED LOG STORE

0|-3

0|-1

0|-1

0|+1

0|+1

Logs go to a dedicated log service that nobody can alter, not even administrators. You go **GLOBAL** with it once, and from now on it covers every project automatically.

The one incident where the logs "got lost" is now a very short story. Of course, every log of every project now sits in one very attractive place.

SDM D3.4 · NIST AU-9

TRA-LOG-3 · v0.8

2 Ask the people it affects

CONSULT AFFECTED PEOPLE EARLY

-2|0

-1|0

Involve the people affected, or their representatives, in the design.

They asked the one question nobody had thought of.

SDM Art. 35(9)

TRA-VOICE-1 · v0.8



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE

1 Just email us

SHARED MAILBOX, MANUAL LOOKUP

0|-1

Offer one email address and look the person up in the systems by hand.

Works, as long as the one person who knows where to look is in today.

SDM D1.6

INV-REQUESTS-1 - v0.8

3 Ticket with a deadline

REQUEST TICKETS WITH ID CHECK

0|-2

0|-1

Run requests through a ticket workflow with an owner, a deadline and an identity check. You go **GLOBAL** with the workflow once, and from now on every project plugs into it.

The deadline is thirty days. The first ticket arrives on day twenty-nine.

SDM D1.6, B1.9 - NIST SI-18(4)

INV-REQUESTS-2 - v0.8

4 Do it yourself

SELF-SERVICE PORTAL

0|-3

0|-1

0|+1

Let people view, correct and export their data in a portal. You go **GLOBAL** with the portal once, and from now on every project shows up in it.

A new front door. Somebody has to lock it.

SDM D1.6 - NIST SI-18(4)

INV-REQUESTS-3 - v0.8

1 Find every copy

CROSS-SYSTEM CHECKLIST

0|-1

List every place where a person's data lives, and walk the list when someone asks.

The list is missing the shared drive. The shared drive knows.

SDM D1.6

INV-ALLDATA-1 - v0.8

4 One search, every system

PERSON-LEVEL LOOKUP ACROSS SYSTEMS

0|-2

0|-1

0|+1

Use a data inventory and ID mapping to find, correct and delete everything about a person. You go **GLOBAL** with the inventory once, and from now on every project is in the index.

To delete a person you first have to link them everywhere. Privacy, meet paradox.

SDM D1.6 - NIST PM-5(1), SI-18(5)

INV-ALLDATA-2 - v0.8

1 Ask for a human

HUMAN REVIEW ON REQUEST

0|-1

0|-1

A person decides again when someone contests an automated result.

The person is called Dave. Dave has 400 other cases.

SDM B1.15

INV-HUMAN-1 - v0.8

2 A person signs it off

NO ADVERSE DECISION ON A SCORE ALONE

-2|0

-1|0

A person has to read the case and sign the decision before any adverse outcome.

Reviewed in four seconds, approved in three. Progress.

SDM B1.15

INV-HUMAN-2 - v0.8

2 Second signature, in writing

DOCUMENTED SECOND REVIEW

-3|0

-1|0

-1|0

A second reviewer writes down the reasons for an adverse decision.

The reasons are "see above".

SDM B1.15

INV-HUMAN-3 - v0.8

1 Just ask us

OPT-OUT PER PURPOSE ON REQUEST

0|-1

Handle an opt-out per purpose when someone asks.

A form for it exists. Finding the form is the real opt-out.

SDM D1.6

INV-SWITCH-1 - v0.8



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE

3 My settings

1

SETTINGS PAGE



Let users decide which optional processing applies to them. Since the settings page is a component any product can embed, you can **REUSE** it in every project now for 1 extra cost per project.

Nobody changes the defaults. Everybody wants to be able to.

SDM D1.6, B1.17

INV-SWITCH-2 · v0.8

3 The big red switch

SWITCH A FUNCTION OFF



Make one function switchable off without stopping the whole system.

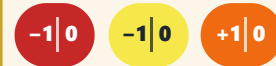
Nobody wants to need it. Everybody wants to know where it is at 3 a.m.

SDM D1.6

INV-SWITCH-3 · v0.8

3 Say yes separately

GRANULAR CONSENT AND WITHDRAWAL



Offer separate choices per purpose. Only relevant if consent is the legal basis. You go **GLOBAL** with the consent platform once, and from now on every project uses it.

"I agree to everything" remains the most popular button.

SDM D1.6, B2 · NIST PT-4(1)

INV-CONSENT-1 · v0.8

3 One click back

JUST-IN-TIME CONSENT



Ask for consent when it becomes relevant and let people withdraw in one step. Only relevant if consent is the legal basis. You go **GLOBAL** with the consent platform once, and from now on every project can use it.

Saying yes took one click. Saying no took four. Somebody fixed it.

SDM B2 · NIST PT-4(2), PT-4(3)

INV-CONSENT-2 · v0.8

Data nobody uses piles up

PROBABILITY

IMPACT

Data Minimisation



Confidentiality



R01 · v0.8

Collected just in case

PROBABILITY

IMPACT

Data Minimisation



Unlinkability



R02 · v0.8

Real data in the test system

PROBABILITY

IMPACT

Data Minimisation



Confidentiality



R03 · v0.8

The system is down

PROBABILITY

IMPACT

Availability



Intervenability



R04 · v0.8

Records lost for good

PROBABILITY

IMPACT

Availability



Integrity



R05 · v0.8



**DATA PROTECTION
RISK GAME**

MEASURE



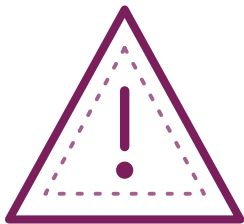
**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

RISK



**DATA PROTECTION
RISK GAME**

RISK



**DATA PROTECTION
RISK GAME**

MEASURE



**DATA PROTECTION
RISK GAME**

RISK



**DATA PROTECTION
RISK GAME**

RISK



**DATA PROTECTION
RISK GAME**

RISK

Wrong data feeds a decision



R06 - v0.8

A record is quietly changed



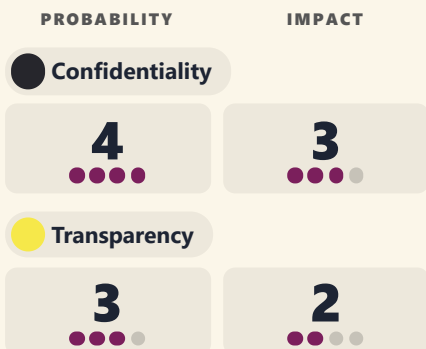
R07 - v0.8

Groups are treated unequally



R08 - v0.8

Staff snoop in records



R09 - v0.8

A supplier sees everything



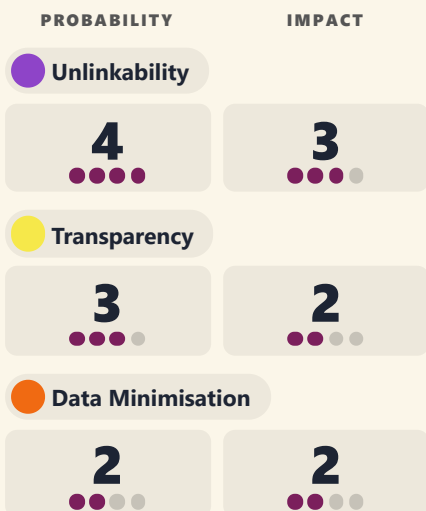
R10 - v0.8

Data walks out the door



R11 - v0.8

Data reused for a new purpose



R12 - v0.8

Datasets get joined



R13 - v0.8

Nobody knows what happens



R14 - v0.8



**DATA PROTECTION
RISK GAME**

RISK



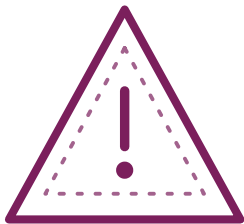
**DATA PROTECTION
RISK GAME**

RISK



**DATA PROTECTION
RISK GAME**

RISK



**DATA PROTECTION
RISK GAME**

RISK



**DATA PROTECTION
RISK GAME**

RISK



**DATA PROTECTION
RISK GAME**

RISK



**DATA PROTECTION
RISK GAME**

RISK



**DATA PROTECTION
RISK GAME**

RISK



**DATA PROTECTION
RISK GAME**

RISK

A decision cannot be explained

PROBABILITY

IMPACT

 Transparency

3



3



 Intervenability

3



3



 Integrity

2



3



R15 - v0.8

No way to correct your data

PROBABILITY

IMPACT

 Intervenability

3



4



 Integrity

3



3



R16 - v0.8

No way to contest a decision

PROBABILITY

IMPACT

 Intervenability

3



4



 Transparency

2



3



R17 - v0.8

Mandatory fun

ALL-HANDS

Nothing happens. The meeting lasts all afternoon, but it decides nothing that touches your project.

The slides had 61 pages. Slide 4 was about you.

EV01.1 - v0.8

Mandatory fun

ALL-HANDS

Nothing happens. The meeting lasts all afternoon, but it decides nothing that touches your project.

The slides had 61 pages. Slide 4 was about you.

EV01.2 - v0.8

Now with oat milk

NEW COFFEE MACHINE

Nothing happens. A better coffee machine does not change a single risk or measure.

Productivity is unchanged. Morale is up 3 percent, according to a survey about the machine.

EV02.1 - v0.8

Now with oat milk

NEW COFFEE MACHINE

Nothing happens. A better coffee machine does not change a single risk or measure.

Productivity is unchanged. Morale is up 3 percent, according to a survey about the machine.

EV02.2 - v0.8

Everyone out. Again.

FIRE DRILL

Nothing happens. Everyone walks out and walks back in to the same project.

The drill takes 40 minutes. The actual fire alarm is still on the backlog.

EV03.1 - v0.8

Everyone out. Again.

FIRE DRILL

Nothing happens. Everyone walks out and walks back in to the same project.

The drill takes 40 minutes. The actual fire alarm is still on the backlog.

EV03.2 - v0.8



**DATA PROTECTION
RISK GAME**

RISK



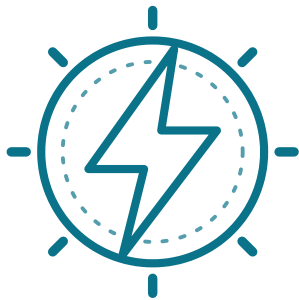
**DATA PROTECTION
RISK GAME**

RISK



**DATA PROTECTION
RISK GAME**

RISK



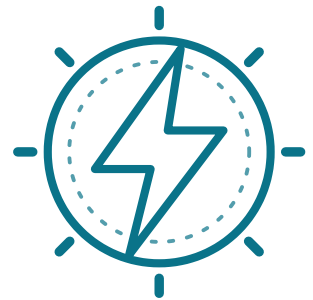
**DATA PROTECTION
RISK GAME**

EVENT



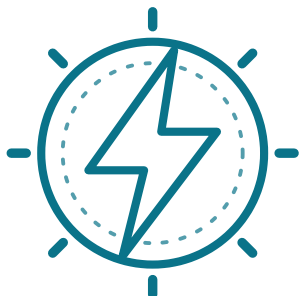
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT

We are a team of teams now

REORG ANNOUNCED

Nothing happens. The org chart changes, the project does not.

Your manager has a new title. Your project has the same problems.

EV04.1 - v0.8

We are a team of teams now

REORG ANNOUNCED

Nothing happens. The org chart changes, the project does not.

Your manager has a new title. Your project has the same problems.

EV04.2 - v0.8

Found in last year's budget

UNSPENT BUDGET

Finance found money left over from last year and nobody asks where it was hiding. Gain 2 coins.

Finance calls it a one-off. Finance says that every year.

EV05.1 - v0.8

Found in last year's budget

UNSPENT BUDGET

Finance found money left over from last year and nobody asks where it was hiding. Gain 2 coins.

Finance calls it a one-off. Finance says that every year.

EV05.2 - v0.8

"This is exactly what I asked for"

SPONSOR IS IMPRESSED

The sponsor is happy, and happy sponsors top up the budget. Gain 1 coin.

He asked for something else. Nobody corrects him.

EV06.1 - v0.8

"This is exactly what I asked for"

SPONSOR IS IMPRESSED

The sponsor is happy, and happy sponsors top up the budget. Gain 1 coin.

He asked for something else. Nobody corrects him.

EV06.2 - v0.8

A coupon, with a smile

VENDOR GOODWILL

A vendor feels generous and hands out a coupon. Gain 2 coins.

Valid for tools you already have. Not for the one you need.

EV07.1 - v0.8

A coupon, with a smile

VENDOR GOODWILL

A vendor feels generous and hands out a coupon. Gain 2 coins.

Valid for tools you already have. Not for the one you need.

EV07.2 - v0.8

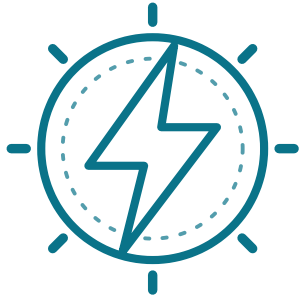
Auto-renews for another year

LICENCE RENEWAL

Apparently the tool is still licensed. Nobody uses it, but cancelling needs a form, so it renewed. Lose 1 coin.

The tool nobody uses has 14 licences. Cancelling needs a form.

EV08.1 - v0.8



**DATA PROTECTION
RISK GAME**

EVENT



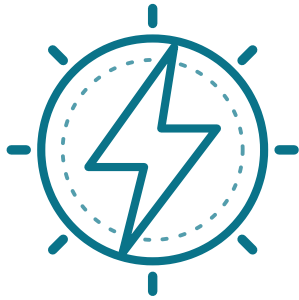
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



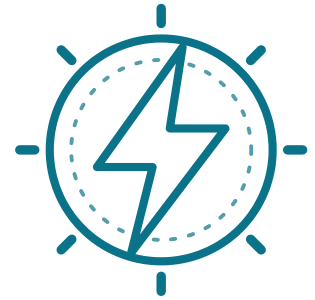
**DATA PROTECTION
RISK GAME**

EVENT



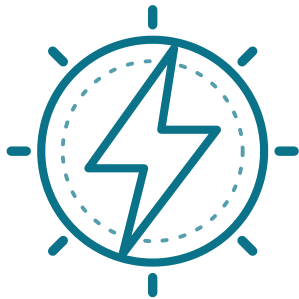
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



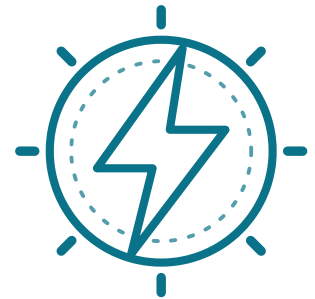
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT

Auto-renews for another year

LICENCE RENEWAL

Apparently the tool is still licensed. Nobody uses it, but cancelling needs a form, so it renewed. Lose 1 coin.

The tool nobody uses has 14 licences. Cancelling needs a form.

EV08.2 · v0.8

The auditors send an invoice

AUDIT FEE

The auditors came, looked around and sent an invoice. You still have to pay it. Lose 2 coins.

Finding: the invoice is correct.

EV09.1 · v0.8

The auditors send an invoice

AUDIT FEE

The auditors came, looked around and sent an invoice. You still have to pay it. Lose 2 coins.

Finding: the invoice is correct.

EV09.2 · v0.8

Billable hours, in the hundreds

CONSULTANTS ARRIVE

Apparently consultants were hired. Nobody remembers why, but you still have to pay them. Lose 2 coins.

They have a framework. It has a logo.

EV10.1 · v0.8

Billable hours, in the hundreds

CONSULTANTS ARRIVE

Apparently consultants were hired. Nobody remembers why, but you still have to pay them. Lose 2 coins.

They have a framework. It has a logo.

EV10.2 · v0.8

Somebody on the team is sick

FLU SEASON

Somebody on the team is out, so there is less capacity. Lose one action for this project, if you still have one.

They are not sick. They are "working from home". On a Tuesday. Wearing pyjamas. Allegedly.

EV11 · v0.8

Nothing leaves this building

BUDGET FREEZE

The budget is frozen and every spend needs a reason. Your next measure may cost at most 10 percent of your remaining coins, and at least 1.

The freeze ends when the quarter ends, or when somebody senior needs a new laptop.

EV12 · v0.8

This could have been an email

TOO MANY MEETINGS

Too many meetings, too little said. Until you play your next measure, the team may only communicate in writing.

Eleven people were invited. Three had something to say. One said it twice.

EV13 · v0.8

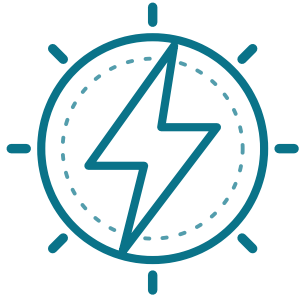
Nobody wants to speak

MORALE IS LOW

Nobody wants to be the one who speaks. Until you play your next measure, everyone says just one word, then somebody else has to say the next word.

Silence, then "synergy". Then more silence.

EV14 · v0.8



**DATA PROTECTION
RISK GAME**

EVENT



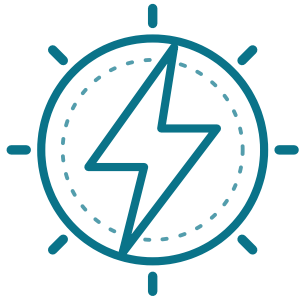
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



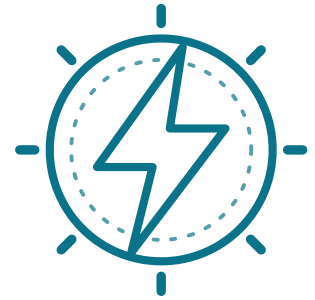
**DATA PROTECTION
RISK GAME**

EVENT



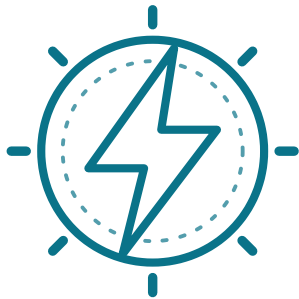
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



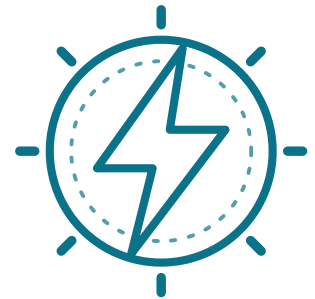
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT

Please explain again why we do this

ESCALATED

Somebody senior wants the whole thing justified again. Explain out loud why risk mitigation is a thing, instead of working on the mitigation. Lose 1 coin for the meeting.

You have a slide for this. The slide has a pie chart. Nobody asked about the pie chart.

EV15 - v0.8

You have until the doors open

ELEVATOR PITCH

You get a minute with the decision maker, and the clock is running. Pitch your next measure to the team in 30 seconds, without using the word "data".

The elevator is stuck between floors. It is the most productive meeting this week.

EV16 - v0.8

Covered, financially

CYBER INSURANCE

It covers the company's costs after an incident, not the people in the data. It takes an action in this project, if one is left. It does nothing for the people in the data.

It pays for the company's losses after an incident. The people in the data get a letter.

EV21 - v0.8

"If anything goes wrong, they pay"

VENDOR LIABILITY CLAUSE

It makes the vendor pay for the vendor's mistakes, not the people in the data. It takes an action in this project, if one is left. It does nothing for the people in the data.

Clause 14b. The vendor pays for the vendor's mistakes, up to the price of the licence.

EV22 - v0.8

Everyone signed. Nobody read it.

SIGNED CONSENT FORM

Everyone signed, so it looks done, but a signature changes nothing about how the data is used. It takes an action in this project, if one is left. It does nothing for the people in the data.

Signed on the first day, between the laptop and the badge.

EV23 - v0.8

Page 52 explains page 41

VERY LONG PRIVACY NOTICE

It is very thorough and nobody reads it, so it protects nobody. It takes an action in this project, if one is left. It does nothing for the people in the data.

Last read by the person who wrote it. Possibly not even then.

EV24 - v0.8

Completion rate: 98 percent

ANNUAL E-LEARNING

Everyone completed it, so it looks done, but the training changes no behaviour. It takes an action in this project, if one is left. It does nothing for the people in the data.

The quiz allows unlimited retries and the answers are in the previous question.

EV25 - v0.8

Valid until the next audit

CERTIFICATE ON THE WALL

It looks good on the wall, but it does not protect the data. It takes an action in this project, if one is left. It does nothing for the people in the data.

It looks very good in the lobby. The lobby is not where the data is.

EV26 - v0.8

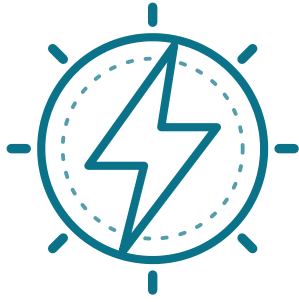
Turns out it was a lot worse

OVERLOOKED

The first assessment missed the worst case. Every goal of every risk in this project gets worse: impact +1.

The first assessment covered the happy path. The happy path was a rumour.

EV18 - v0.8



**DATA PROTECTION
RISK GAME**

EVENT



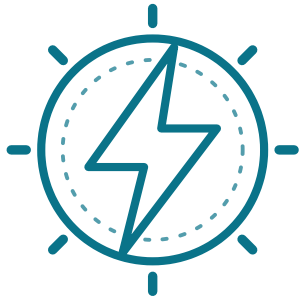
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



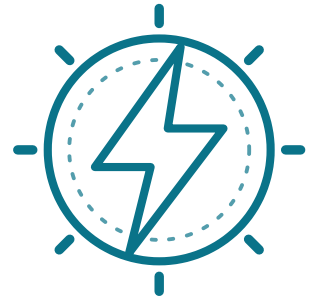
**DATA PROTECTION
RISK GAME**

EVENT



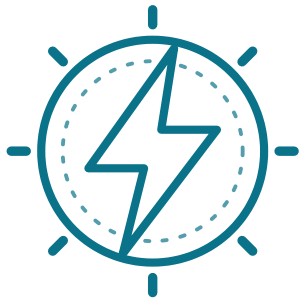
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



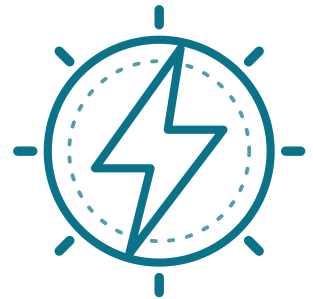
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT

"I have seen this before"

SEEN IT BEFORE

Somebody experienced says they have handled this before, and this time they are right. One random risk of this project gets better: the probability of its worst goal drops by 1.

He has seen everything before. He has also said "trust me" since 2009. It works about half the time.

EV19 - v0.8

Switched off in the config

NEVER SWITCHED ON

The measure was never actually switched on. The measure you played last does nothing for the rest of this project. It still counts as an action.

The ticket says done. The ticket has never been wrong. Until now.

EV20 - v0.8

An extra pair of hands

INTERN JOINS

An extra pair of hands makes room for one more measure. Gain one action for this project.

They have opinions about tabs and spaces. They also cleared the backlog, by deleting it.

EV27 - v0.8

Thirty hours, one pizza

HACKATHON

A weekend of pizza and focus produces more than a month of meetings. Gain one action for this project.

The demo works. Nobody can say why. Nobody touches it.

EV28 - v0.8

Out of office until the 14th

SUMMER HOLIDAYS

Half the team is on holiday and the other half is on the beach in spirit. Lose up to two actions for this project, if you still have them.

The auto-reply says "in urgent cases, contact me". The number is not on the list.

EV29 - v0.8

Trust falls at a conference hotel

TEAM OFFSITE

The team is away for trust falls and the work waits. Lose one action for this project, if you still have one.

The project was discussed for eleven minutes. The trust fall took longer.

EV30 - v0.8

Sorry, what language was that?

LANGUAGE BARRIER

Nobody on the team shares a common language today. Until you play your next measure, nobody may speak English.

Gestures, drawings and one confident "ok". The decision is made anyway.

EV31 - v0.8

Arr, the quarterly review

PIRATE DAY

It is pirate day and management insists on joining in. Until you play your next measure, everybody talks like a pirate.

The auditors approve of the vocabulary. The parrot is not on the asset list.

EV32 - v0.8

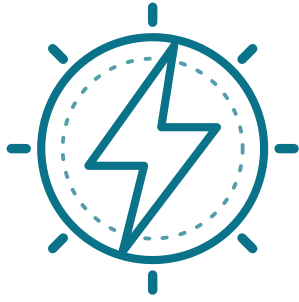
Is that a statement?

QUESTIONS ONLY

The team has decided to challenge every statement. Until you play your next measure, you may only speak in questions.

Could we agree on that? Would that be a decision? Who would write it down?

EV33 - v0.8



**DATA PROTECTION
RISK GAME**

EVENT



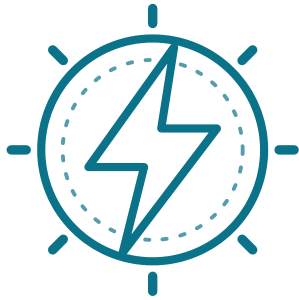
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



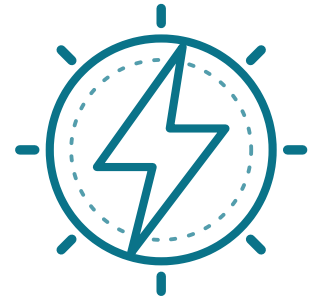
**DATA PROTECTION
RISK GAME**

EVENT



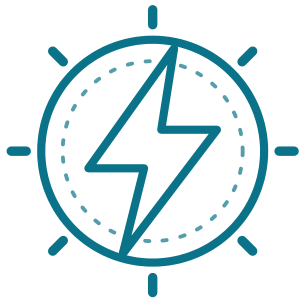
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



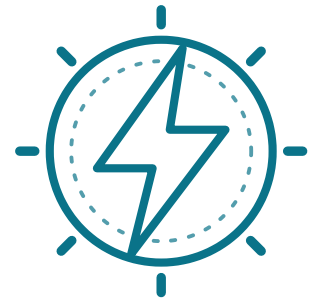
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT

Please mute yourself

SILENT STAND-UP

The call has no sound and everyone has to cope. Explain your next measure to the team without speaking: gestures only.

Nine people agree. One has understood something different. This is how projects work.

EV34 - v0.8

Keep it down, the walls have ears

WHISPER NETWORK

Somebody says the walls have ears and the team believes it. Until you play your next measure, everybody whispers.

The walls have ears. The ears have a ticket system.

EV35 - v0.8

Everyone sounds professional

THIRD PERSON

The team has been told to sound more professional. Until you play your next measure, everybody speaks about themselves in the third person.

The architect agrees. The architect has always agreed.

EV36 - v0.8

Fresh eyes, no context

NEW HIRE DECIDES

A new hire has no history with the project, so they get to decide. The newest member of the team decides which measure you play next.

They ask why. Nobody has a good answer. That is the audit finding.

EV37 - v0.8

No time to prepare

JUST WING IT

There is no time to prepare, so the team improvises. Play three random cards from your hand, in order, whatever they are. If one of them cannot be played, the project ends.

It worked on the demo. This is the demo.

EV38 - v0.8

Let's reset and align

NEW PROJECT MANAGER

A new project manager wants to start fresh, and nobody can stop it. Every card played in this project is gone, and so are all the yellow cards on the table. The coins you spent on them are gone too.

She has a new template. It has a section called Lessons Learned. It is empty.

EV39 - v0.8

Management saw a demo

LET'S ADD SOME AI

Management saw a demo and wants it in the project. A new goal joins one risk of this project.

The model is a black box. The business case is a slide. The risk register just got longer.

EV40 - v0.8

The chatbot went live unchecked

CHATBOT FOR EVERYONE

The chatbot answers customers, sometimes with their neighbours' data. It went live before anyone checked it. A new goal joins one risk of this project.

Launched on a Friday, as a pilot, to everyone. Rollback plan: "turn it off and on".

EV41 - v0.8

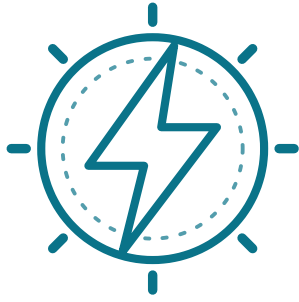
Somebody pushed it to production

ROGUE ACTOR

Somebody pushed an unreviewed change to production. The project goes live now. It ends at once, with the risks as they are. Remaining plays are lost.

The commit message says "fix". The change touches 214 files.

EV17 - v0.8



**DATA PROTECTION
RISK GAME**

EVENT



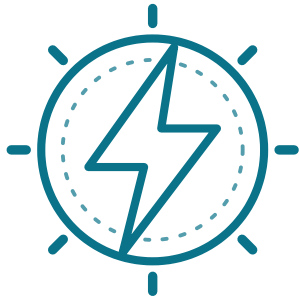
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



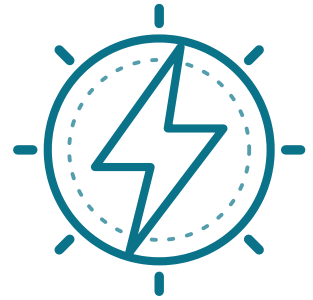
**DATA PROTECTION
RISK GAME**

EVENT



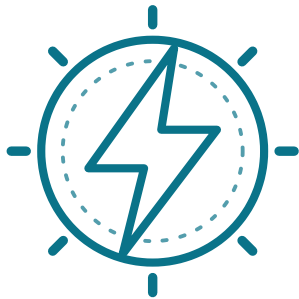
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



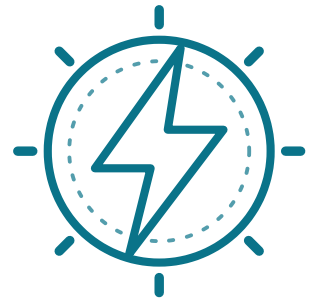
**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT



**DATA PROTECTION
RISK GAME**

EVENT